

2017-05-18 TRAFFIC ANALYSIS EXERCISE - ANSWERS

QUESTIONS:

Which of the two emails caused the infection on Roger Finster's computer?

ANSWERS:

The email at 15:55 UTC with the subject line: We couldn't deliver your package #03148487

Summary: On 2017-05-18 at approximately 21:45 UTC, Roger Finster's computer (host name FINSTER-101-PC) was infected with Kovter malware after viewing a fake FedEx email with a PDF attachment. The PDF file had an embedded Word document with malicious macros. Enabling the macros caused Kovter malware to be downloaded and run on the victim's Windows computer.

DETAILS:

This one's pretty easy. First, we'll look at the pcap, then we'll review the emails to find the associated malware matches indicators from the pcap.

As always, I recommend you set up Wireshark in accordance with my guide at:

- <http://www.malware-traffic-analysis.net/tutorials/wireshark/index.html>

Open the pcap, and filter on **http.request** to see the indicators.

Filter: http.request ▼ Expression... Clear Apply Save			
Dst	port	Host	Info
23.215.98.193	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1
13.58.26.56	80	regereeeeeee.com	GET /gate2.php?ff1 HTTP/1.1
52.84.113.251	80	52.84.113.251	POST / HTTP/1.1 (application/)
52.84.113.251	80	52.84.113.251	POST / HTTP/1.1 (application/)
123.56.154.143	80	123.56.154.143	POST / HTTP/1.1 (application/)
166.23.105.186	80	166.23.105.186	POST / HTTP/1.1 (application/)
52.84.113.251	80	52.84.113.251	POST / HTTP/1.1 (application/)
123.56.154.143	80	123.56.154.143	POST / HTTP/1.1 (application/)
166.23.105.186	80	166.23.105.186	POST / HTTP/1.1 (application/)
211.149.142.124	80	211.149.142.124	POST / HTTP/1.1 (application/)
52.84.113.251	80	52.84.113.251	POST / HTTP/1.1 (application/)
123.56.154.143	80	123.56.154.143	POST / HTTP/1.1 (application/)
166.23.105.186	80	166.23.105.186	POST / HTTP/1.1 (application/)

Shown above: Some indicators from the exercise pcap.

Some people might recognize some of this traffic as post-infection Kovter activity. If not, you can review the Suricata alerts and find several alerts for Kovter.

2017-05-18 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Date/Ti...	△	Src IP	SPort	Dst IP	DPort	Pr	Event Message
2017-05-18 ...		172.16.8.38	49211	13.58.26.56	80	6	ETPRO TROJAN JS Loader Payload Request
2017-05-18 ...		13.58.26.56	80	172.16.8.38	49211	6	ETPRO TROJAN JS Loader PE Download
2017-05-18 ...		13.58.26.56	80	172.16.8.38	49211	6	ETPRO TROJAN JS Loader PE Download
2017-05-18 ...		13.58.26.56	80	172.16.8.38	49211	6	ETPRO TROJAN JS Loader PE Download
2017-05-18 ...		13.58.26.56	80	172.16.8.38	49211	6	ETPRO TROJAN JS Loader PE Download
2017-05-18 ...		13.58.26.56	80	172.16.8.38	49211	6	ETPRO TROJAN JS Loader PE Download
2017-05-18 ...		172.16.8.38	49249	52.84.113.251	80	6	ET TROJAN Win32.Kovter Client CnC Traffic
2017-05-18 ...		172.16.8.38	49250	52.84.113.251	80	6	ETPRO TROJAN WIN32/KOVTER.B Checkin 2
2017-05-18 ...		172.16.8.38	49402	163.198.51.39	80	6	ET TROJAN Win32.Kovter Client CnC Traffic
2017-05-18 ...		172.16.8.38	49503	52.84.113.251	80	6	ETPRO TROJAN WIN32/KOVTER.B Checkin 2
2017-05-18 ...		172.16.8.38	49543	184.28.201.200	80	6	ET TROJAN Win32.Kovter Client CnC Traffic
2017-05-18 ...		172.16.8.38	49578	184.86.17.34	80	6	ET TROJAN Win32.Kovter Client CnC Traffic

Shown above: Alerts for Kovter after .JS downloader alerts from the Suricata list.

Now let's take a look at the first email at 15:45 UTC

From: "assistant@foxdifferlaw.com" <assistant@foxdifferlaw.com>

Date: Thursday, May 18, 2017 at 15:45 UTC

To: <roger.finster@finsters-fine-jewelry.com>

Subject: RE: RE: invoice #67878457417

I tried to call you but it went into voice mail.

The finsters-fine-jewelry.com invoice is ready:

[Invoice 67878457417](#)

Please get back to me with the wire confirmation.

Regards,

Anthony Harris

TEL: (775) 527-8663

Fax: (775) 527-5702

Email: assistant@foxdifferlaw.com

[http://pardintworeb.ru/viewdoc/
file.php?document=MTIzNGJy
YWRAeW91ci1kb21haW4uY2
9tNTY3OA==](http://pardintworeb.ru/viewdoc/file.php?document=MTIzNGJyYWRAeW91ci1kb21haW4uY29tNTY3OA==)

On Thu, May 14th 2017 at 5:33 PM roger.finster@finsters-fine-jewelry.com wrote:

Send me the fucking invoice already if you want your money.

Shown above: The first email.

2017-05-18 TRAFFIC ANALYSIS EXERCISE - ANSWERS

There are no attachments, and the victim would have clicked on the link to infect their computer. That domain and link does not appear anywhere in the pcap, so we can safely rule this one out. That means the other email is the likely culprit.

From: FedEx InSight <amwxihya607@how-to-grow-facial-hair-fast.com>
Date: Thursday, May 18, 2017 at 15:55 UTC
To: <roger.finster@finsters-fine-jewelry.com>
Subject: We couldn't deliver your package #03148487

Hello,

We've tried to deliver your package today, but the attempt wasn't successful.

Please review the delivery confirmation attached.

It's our pleasure to help you.

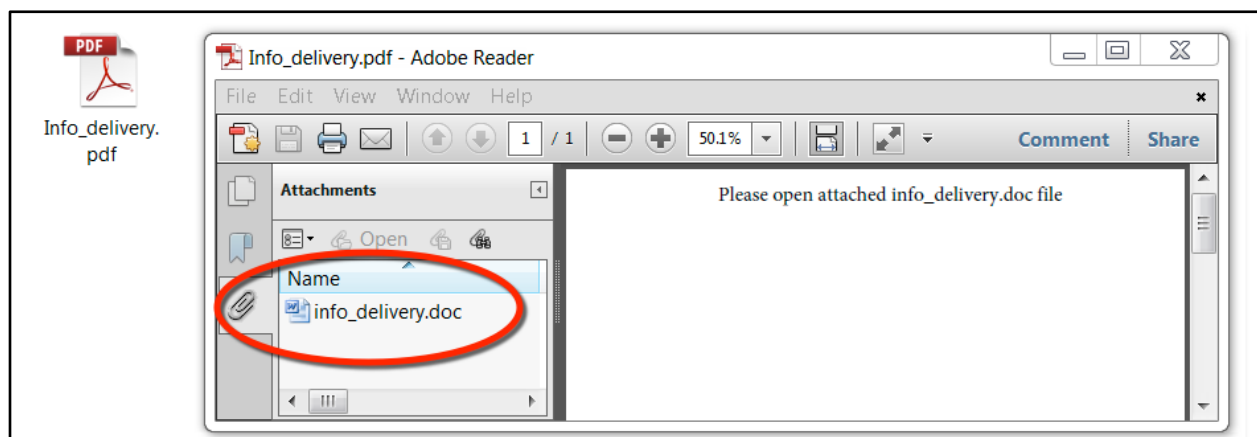
Mistie Kinaj - FedEx Office Supervisor



Info_delivery.
pdf

Shown above: The second email.

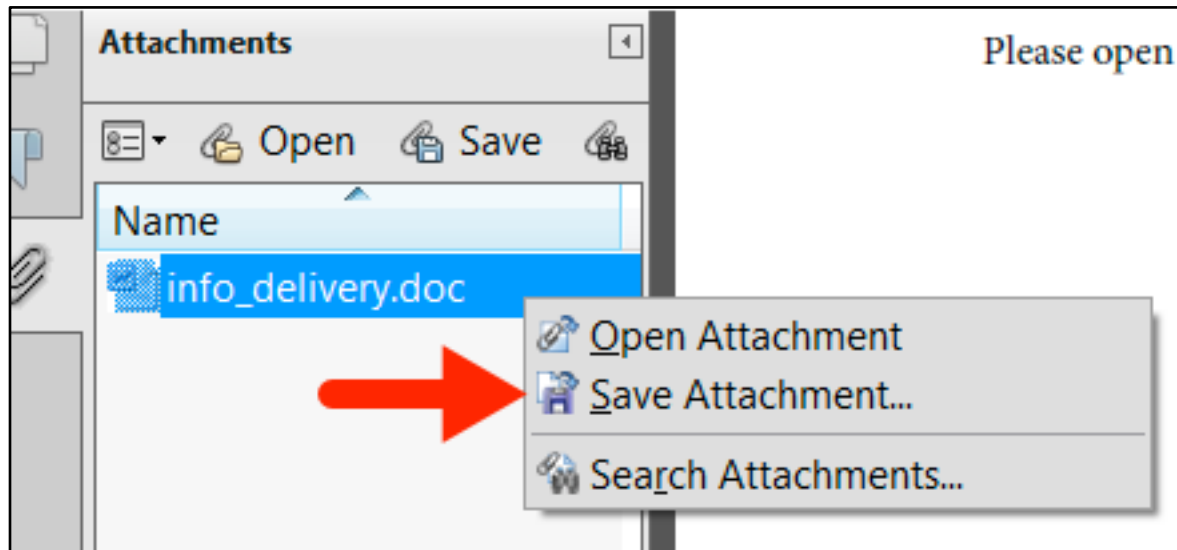
The second email at 15:55 UTC has a PDF attachment. This PDF attachment has an embedded Word document



Shown above: Word document embedded in the PDF file.

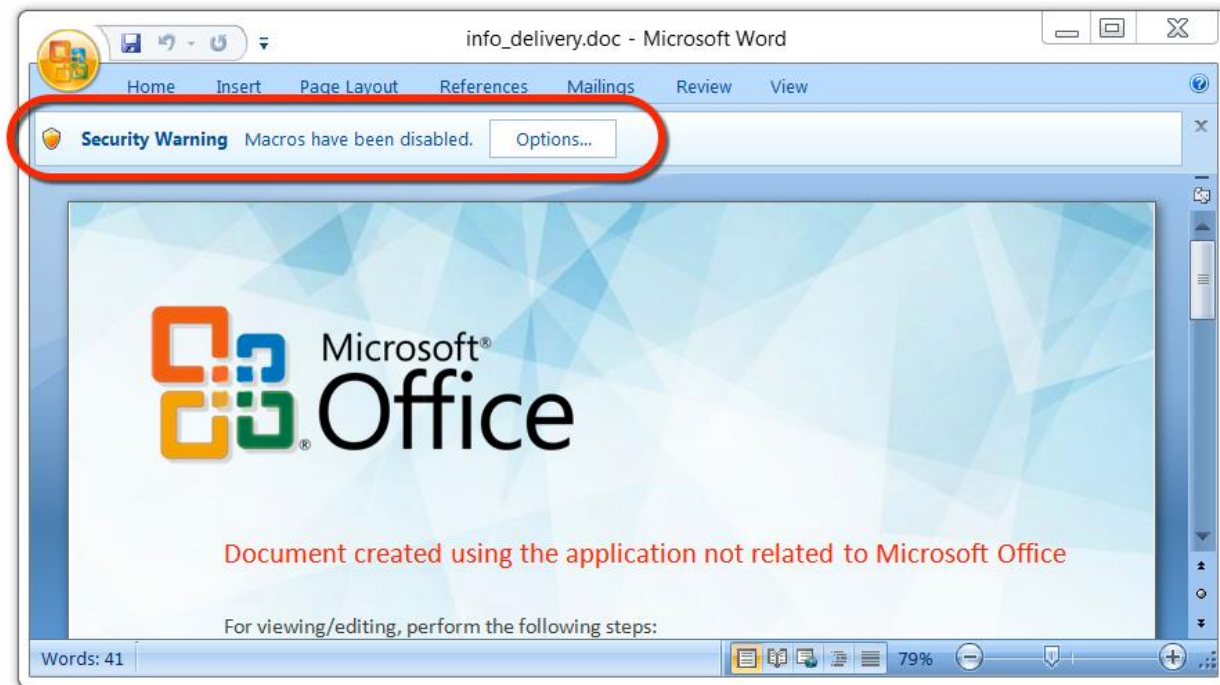
2017-05-18 TRAFFIC ANALYSIS EXERCISE - ANSWERS

If you want to see what the file hash is for the malicious Word document, just extract it from the PDF file as shown below:



Shown above: extracting the Word document from the PDF file.

A quick check of the Word document shows it has macros.



If you extract the word document, it has the following SHA256 hash:

17870a9de6649c9c44ad0ae0d9ffefb4b2f4a4a6f2b70ff79ea2fcc26d60b0ad

2017-05-18 TRAFFIC ANALYSIS EXERCISE - ANSWERS

If you search for that has on Google, you'll find it has already been submitted to hybrid-analysis.com and malwr.com.

- [Hybrid Analysis \(Payload Security\) link](#)
- [Malwr.com link](#)

If you review the results from the analysis, you'll find the same indicators (domains, URLs, and IP addresses) as seen in the exercise pcap. This is the email used to infect Roger Finster's computer!